



Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 3:	Análise de Vulnerabilidades
Atividades:	Análise de Vulnerabilidades com Nessus e Nuclei
Nome:	Luiz Eduardo de Andrade

1. Introdução

Estas atividades fazem parte do módulo *Análise de Vulnerabilidades*, para a qual utilizamos a sala Nessus do TryHackMe - <https://tryhackme.com/r/room/rpnessusredux> e executamos o Nuclei no site <https://brokencrystals.com/>.

No contexto desta sala, nosso foco é:

- 1) Executar o scan de vulnerabilidades Nessus na rede e em serviços web;
- 2) Utilizar as opções de scanner de varreduras como varredura de portas, varreduras de host, scan de malware, scans avançados para ter melhores resultados ;
- 3) Executar o scan de vulnerabilidades Nuclei no site <https://brokencrystals.com/> verificar as vulnerabilidades que o site possui.
- 4) Classificar as vulnerabilidades no site <https://brokencrystals.com/> e descrever cada uma delas.

A sala do TryHackme é composta por cinco tarefas:

- 1) Introdução: explicação teórica do conteúdo sobre a ferramenta NESSUS (sem atividade prática).
- 2) Instalação: atividade prática de instalação do Nessus dentro do Kali Linux.
- 3) Navegação e scans: atividade focada na navegação pelas diversas funcionalidades do Nessus e as opções que temos para fazer os escaneamentos como aplicações web, autenticação de hosts, scans de malware, escaneamento de rede básica entre outras.
- 4) Escaneamento: exercício prático utilizando o escaneamento em redes básicas, em portas, verificando versões do apache.
- 5) Escaneando uma aplicação Web: exercício prático escaneando uma aplicação Web para encontrar informações sobre versões, extensões de arquivos, vulnerabilidades.

2.1. Configuração do ambiente

Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

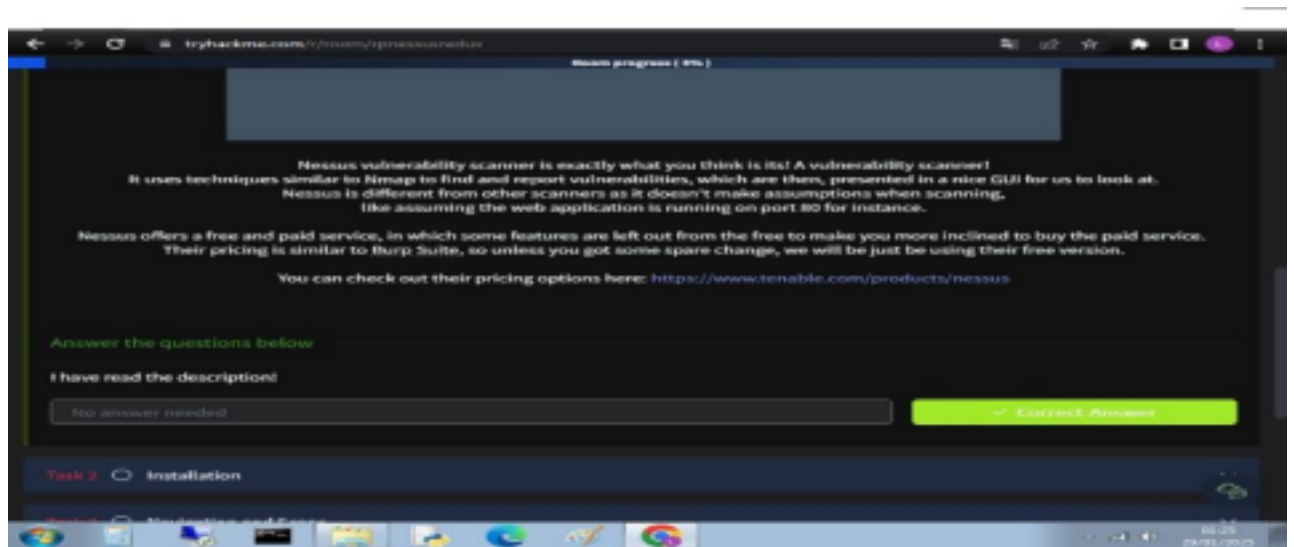
- 1) Acessar o site: <https://tryhackme.com/r/room/rpnessusredux>
- 2) Utilizar a VM do Kali Linux: Para instalar o Nessus e fazer as atividades do TryHackme.
- 3) Baixar o Nuclei dentro da máquina virtual do Kali Linux
- 4) Executar o nuclei no site: <https://brokencrystals.com/>

2.2. Atividade prática Nessus

O objetivo desta atividade é realizar as 5 tarefas propostas no TryHackme

2.3. Atividade 1 - Introdução

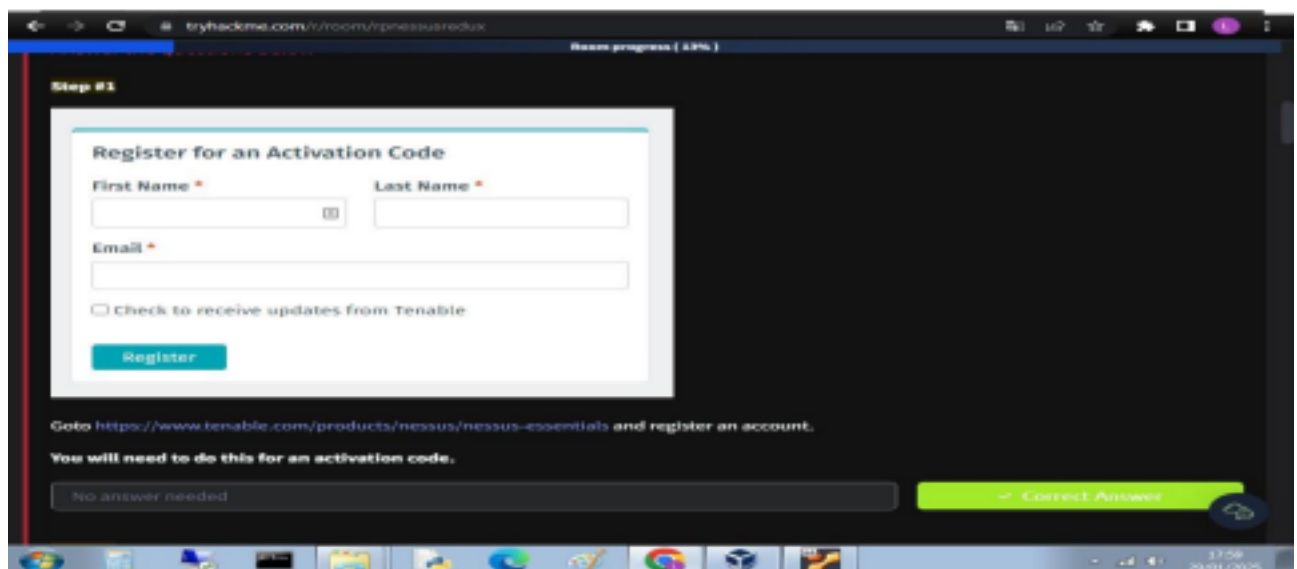
O Nessus é um scanner de vulnerabilidades que são apresentadas em uma interface gráfica, para que possamos analisar melhor as vulnerabilidades, o Nessus não faz suposições ao fazer o escaneamento como o aplicativo Web na porta 80, o Nessus tem a versão gratuita e paga caso queira mais funcionalidades.



2

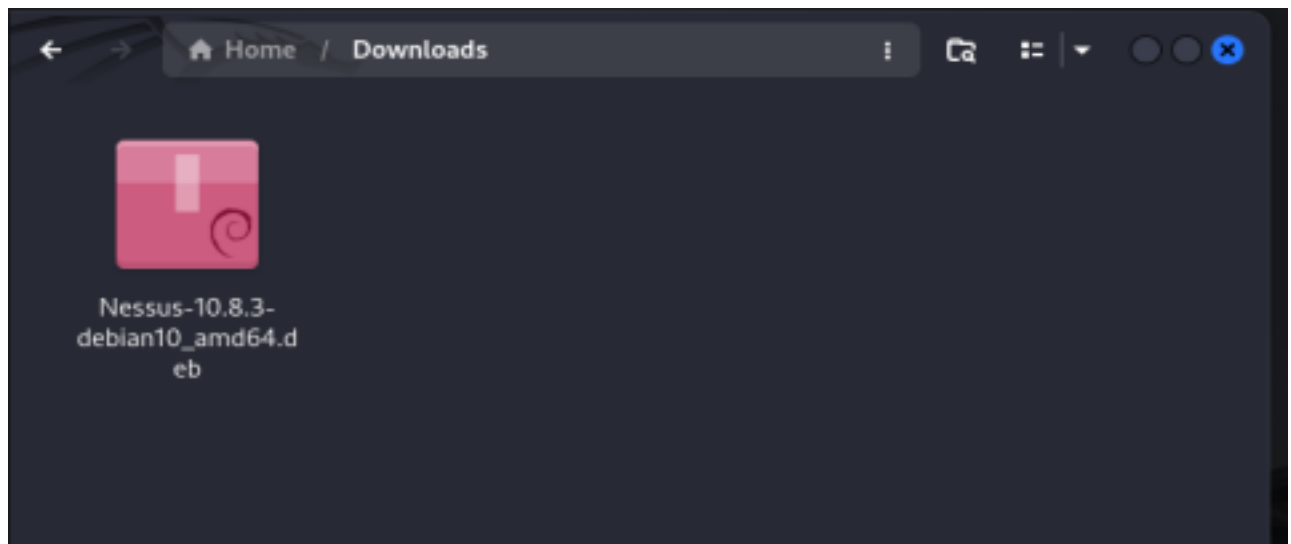
2.4. Atividade 2 – Instalação

Passo 1 – Abra o browser e digite <https://www.tenable.com/products/nessus/nessus-essentials> e registre sua conta



Passo 2 Agora faça o download do `debian6_amd64.deb` file

Salve o arquivo na sua pasta Downloads



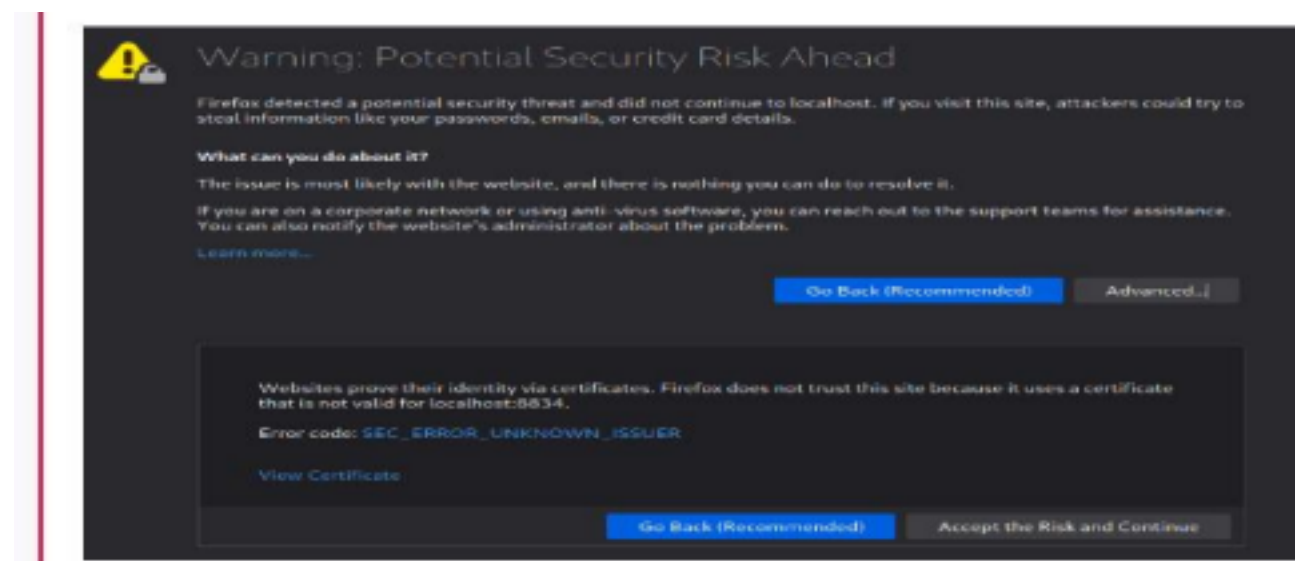
Passo 3 – Abra o terminal e execute o seguinte comando: `sudo dpkg -i Nessus-10.8.3-debian10_amd64.deb`

```

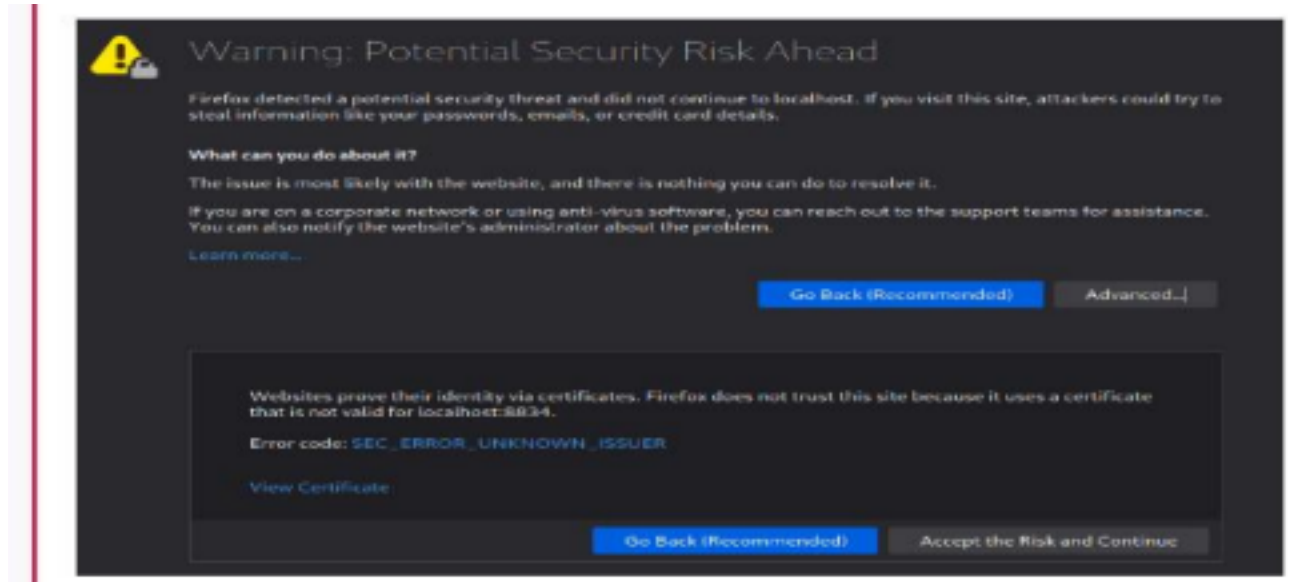
(kali@kali:~/Downloads)
$ sudo dpkg -i Nessus-10.8.3-debian10_amd64.deb
[sudo] password for kali:
Selecting previously unselected package nessus.
(Reading database ... 459982 files and directories currently installed.)
Preparing to unpack Nessus-10.8.3-debian10_amd64.deb ...
Unpacking nessus (10.8.3) ...
Setting up nessus (10.8.3) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KDKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass

```

Passo 4 – Inicie o Nessus com o seguinte comando: `sudo /bin/systemctl start nessusd.service`



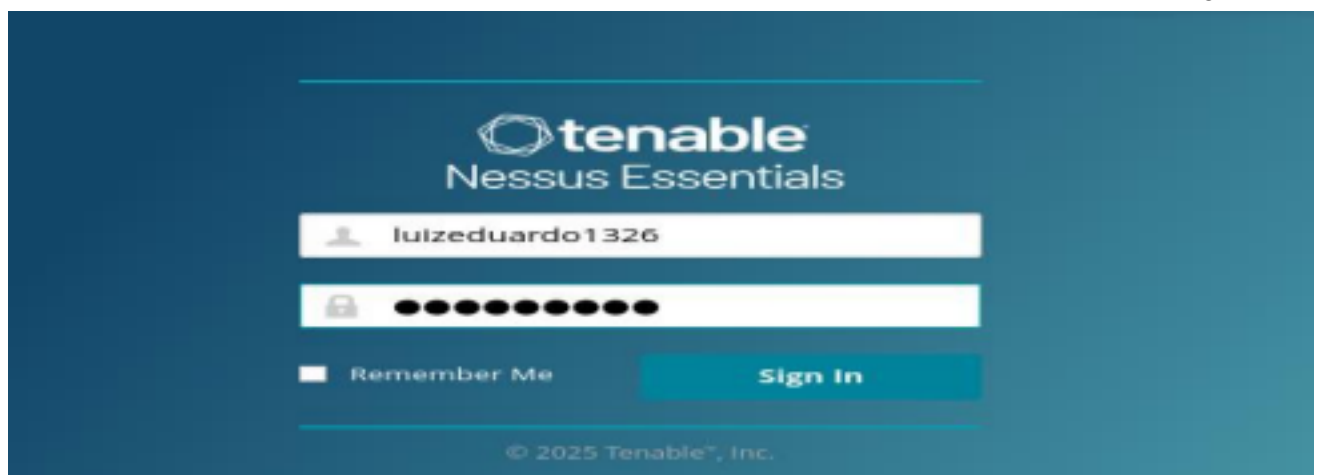
Passo 5 – Abra o Firefox e digite a seguinte URL: `https://localhost:8834/` vai aparecer a tela que não está em uma conexão segura clique em Advanced e Accept the Risk and Continue.



Passo 6 – Agora você vai iniciar o scanner selecionando a opção Register for Nessus Essentials



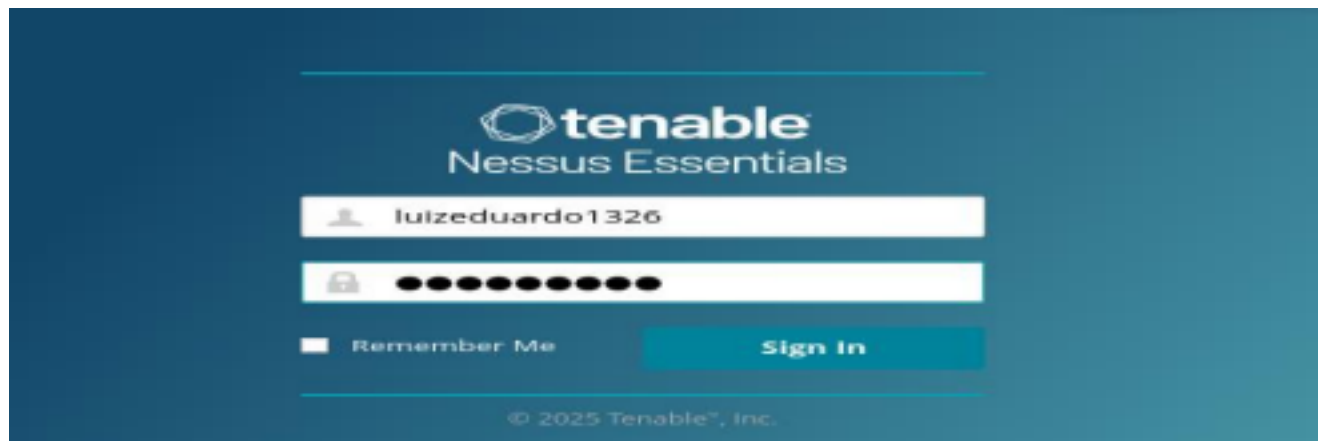
Passo 7 – Cadastre nome e password sempre faça uma senha forte!



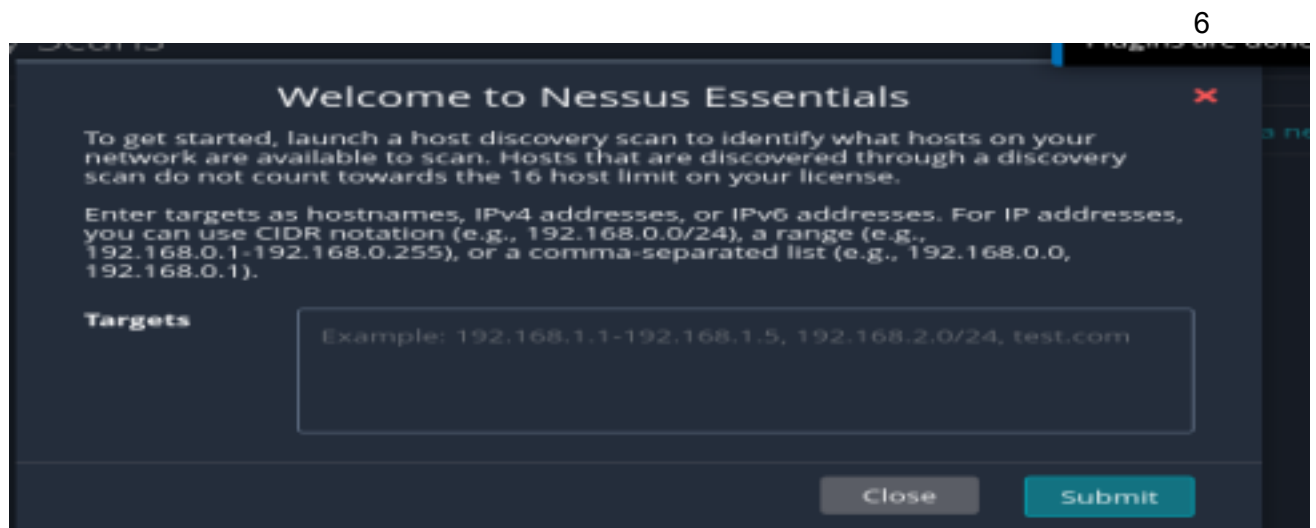
Passo 8 – O Nessus instalará os plugins na sua VM, depende da conexão com a internet e do hardware da VM, se o progresso parar é que não tem espaço no HD da VM



Passo 9 – Faça login com as credenciais já cadastradas



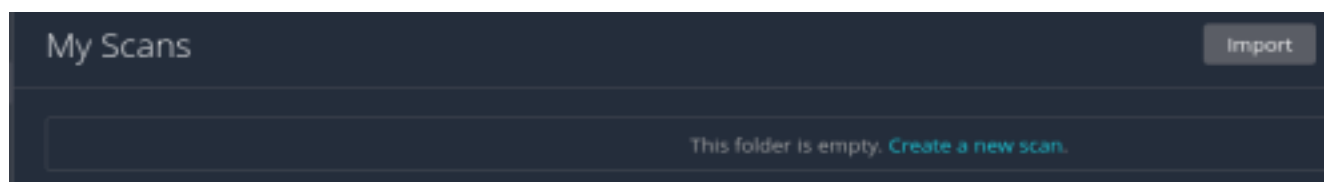
Passo 10 – Você instalou o Nessus com sucesso



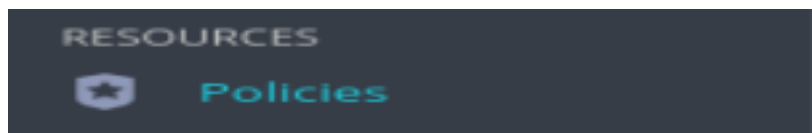
2.5. Atividade 3 – Navegação e Escaneamento

Pergunta 1 - Qual é o nome do botão usado para iniciar uma varredura?

R: New Scan

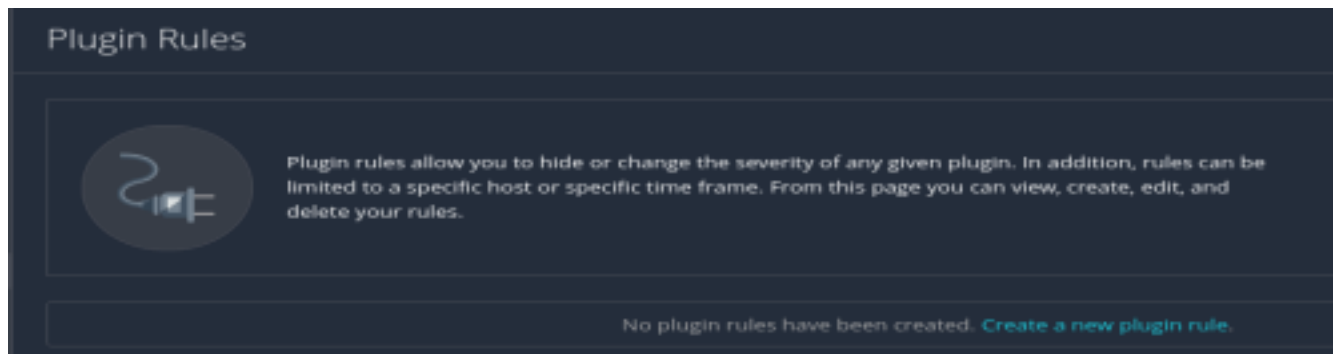


Pergunta 2 - Qual opção do menu lateral nos permite criar modelos personalizados ? R:



Pergunta 3 - Qual menu nos permite alterar as propriedades do plugin, como ocultá-los ou alterar sua gravidade?

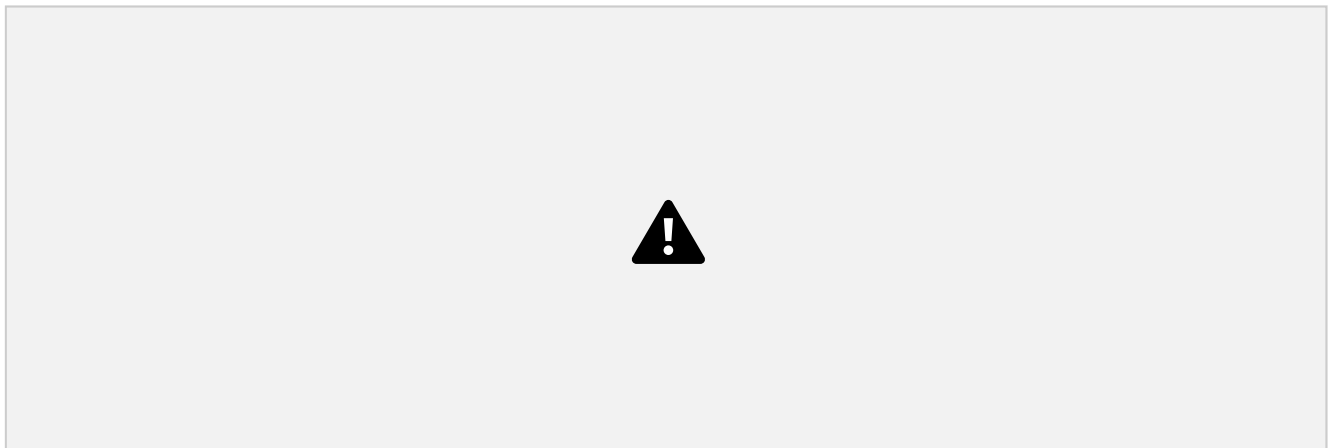
R: Plugin Rules



7

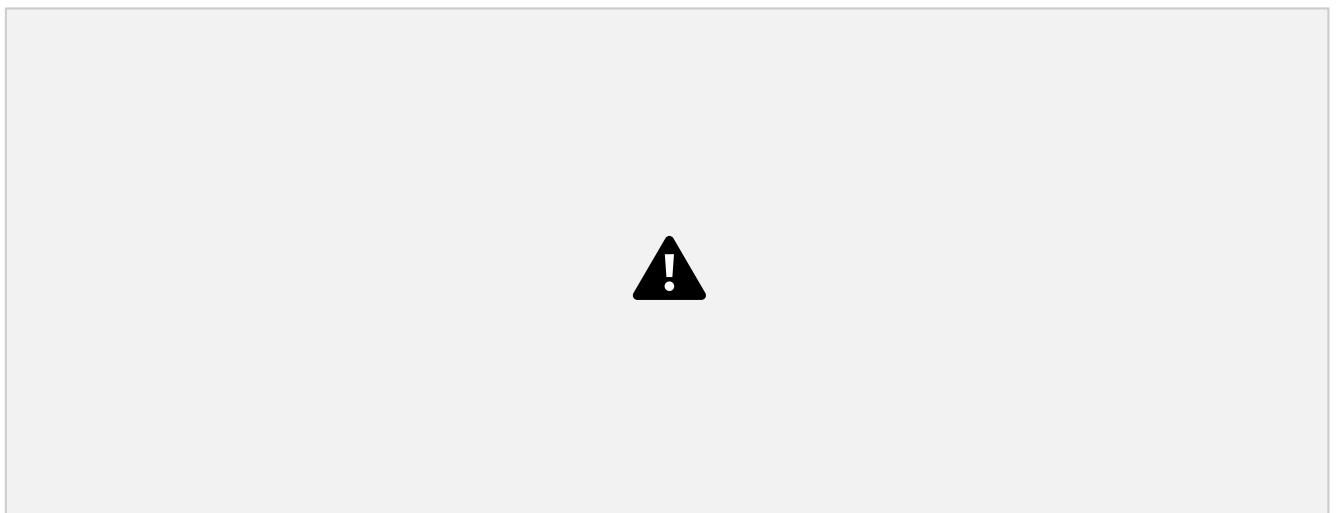
Pergunta 4 - Na seção ' Modelos de verificação ', depois de clicar em ' Nova verificação ', qual verificação nos permite ver simplesmente quais hosts estão ativos?

R: Host Discovery



Pergunta 5 - Um dos tipos de varredura mais úteis, considerado " adequado para qualquer host"?

R: Basic Network Scan



Pergunta 6 - Qual verificação permite que você ' Autentique-se em hosts e enumere atualizações ausentes '?



Pergunta 7 - Qual verificação é usada especificamente para escanear aplicativos da Web ? R: Web Application Tests



2.6. Atividade 4 – Navegação e Escaneamento

Pergunta 1 - Crie um novo ' Basic Network Scan ' visando a VM implantada. Qual opção podemos definir em ' BASIC ' (à esquerda) para definir um horário para que esse scan seja executado? Isso pode ser muito útil quando o congestionamento da rede é um problema.

R: Schedule



Pergunta 2 - Em ' DISCOVERY ' (à esquerda), defina o ' Scan Type ' para cobrir as portas 1- 65535. Como esse tipo é chamado?

R: Port scan (all ports)



Pergunta 3 - Qual ' Tipo de digitalização ' podemos alterar em ' AVANÇADO ' para uma conexão de menor largura de banda?

R: Scan low bandwidth links



Com essas opções definidas, inicie a verificação.

Pergunta 4 - Após a conclusão da verificação, quais ' Vulnerabilidades ' na família ' Scanners de portas ' podemos visualizar os detalhes para ver as portas abertas neste host?

R: Nessus SYN scanner



Pergunta 5 - Qual versão do servidor Apache HTTP é informada pelo Nessus?

R: 2.4.99



2.7. Atividade 5 – Escaneando um aplicativo Web

Pergunta 1 - Qual é o ID do plugin que determina o tipo e a versão do servidor

HTTP? R: 10107



Pergunta 2 - Qual página de autenticação é descoberta pelo scanner que transmite credenciais em texto simples?

R: login.php

Pergunta 3 - Qual é a extensão do arquivo de backup de configuração?

R: .bak

Pergunta 4 - Qual diretório contém documentos de exemplo? (Este estará em um diretório

php) R: /external/phpids/0.6/docs/examples/

Pergunta 5 - A qual vulnerabilidade esse aplicativo é suscetível que está associada ao X-Frame Options?

R: Clickjacking

2.8. Análise dos Resultados:

Foi realizada a instalação do Nessus no Kali Linux

Interpretação dos resultados:

- 1) Exploramos diversas ferramentas no Nessus para ter acesso as portas, os hosts, ao aplicativo web, utilizando calendário para agendar um melhor horário para que o escaneamento seja feito, escaneamentos de todas as portas para verificar quais estão abertas e pegar informações sobre os serviços, feita varredura com menor largura de banda para o scanner fazer menos “barulho” ;

12

- 2) No aplicativo web conseguimos o ID do plugin no HTTP, conseguimos as credenciais em texto claro no login.php, a extensão do arquivo de backup que é .bak e o aplicativo é vulnerável a clickjacking;
- 3) No software de varreduras de vulnerabilidades encontramos duas vulnerabilidades médias e uma vulnerabilidade alta.
- 4) Uma vulnerabilidade de git, uma de banco de dados e uma de arquivo .env que vazou login, senhas e chaves de API

2.9. Atividade Prática Nuclei:

O objetivo deste laboratório é utilizar o software Nuclei no site: <https://brokencrystals.com/>

2.10. Execução no Kali Linux



2.11. Vulnerabilidades encontradas

Foram encontradas 2 vulnerabilidades médias e uma alta, não foram encontradas vulnerabilidades baixas e críticas.



2.12. Arquivos baixados das vulnerabilidades



2.13. Acesso aos arquivos baixados

<https://brokencrystals.com/.git/config> - arquivos gits desprotegidos git é um repositório de código aberto.



14

<https://brokencrystals.com/.svn/wc.db> - acesso ao banco de dados o nome das tabelas, configuração de banco de dados



<https://brokencrystals.com/.env> – possui credenciais de login, senhas e chaves de API





15

3. Considerações finais

Nesta sala, exploramos técnicas da Análise de Vulnerabilidades com os softwares Nessus e o Nuclei cada scan de vulnerabilidade tem seus próprios bancos de dados, o que pode resultar em falsos positivos ou não encontrar uma vulnerabilidade que pode ser explorada.

As principais lições aprendidas incluem:

- 1) Podemos fazer uma varredura manual pois ela é mais silenciosa e tem menor risco de ser percebida pelo sistema do alvo.
- 2) Diferentes scanner podem apresentar resultados diferentes, sempre bom utilizar as varreduras manuais para ter certeza.
- 3) O escaneamento feito por scanners automáticos são muito mais fáceis de operar, mas tem suas limitações conforme explicado acima.
- 4)

Os scanners de vulnerabilidades são ótimos para economizar tempo, mas precisamos ainda das análises manuais para ter maior precisão que o ataque irá funcionar.

Temos diversas opções nos scanners automáticos para facilitar a nossa busca, esta fase é muito importante para um TDI porque precisamos coletar o maior número de informações para explorar as vulnerabilidades.

4. Referências

Site: <https://tryhackme.com/r/room/rpnessusredux>

